INFORME TÉCNICO DE AUDITORÍA DE SEGURIDAD EN SISTEMAS INFORMÁTICOS Y ANÁLISIS DE VULNERABILIDADES WEB

Proyecto VULNAWEB (PAI 3): Postura de Seguridad Integral (Endpoints, Navegadores, BYOD Móvil y DAST Web) para la Universidad Pública "U-Secure"

Asignatura:	Seguridad en Sistemas Informáticos y en Internet (SSII)
Institución Académica:	E.T.S. de Ingeniería Informática — Universidad de Sevilla
Entidad Consultora:	INSEGUS (Informática y Seguridad del Sur)
Equipo Auditor:	**Security Team 3 (Grupo 3)**
Analistas de Seguridad:	Kleber Leonardo de Carvalho, Paula Benítez, Luigui Juan, Guillermo Ramos
Destinatario:	Área de Ciberseguridad / CISO — Universidad Pública U-Secure
Fecha de Emisión:	Noviembre de 2026
Versión del Documento:	2.0 (Versión Final Oficial)
Clasificación:	**CONFIDENCIAL / USO INTERNO (RESTRICTED TLP:AMBER+)**

Control de Versiones del Documento:

Versión	Fecha	Autor(es)	Resumen de Modificaciones Técnicas
`0.1`	26/10/2026	Security Team 3	Definición del alcance técnico y matriz de auditoría según PAI-3.
`0.5`	27/10/2026	Security Team 3	Auditoría base de endpoints Linux (Lynis), script de hardening y validación ≥ 70.
`0.8`	03/11/2026	Security Team 3	Directivas corporativas de navegador (policies.json), auditoría BYOD móvil.
`1.0`	03/11/2026	Security Team 3	Despliegue DAST con ZAP, fuzzing Top 10 (SQLi, XSS, LFI) y código seguro PHP.
`2.0`	04/11/2026	Security Team 3	Telemetría en terminal real Samsung A55 Knox, Breakpoints MitM, matrices de evidencias y dictamen final.

CONFIDENTIAL

ÍNDICE GENERAL DE CONTENIDOS

1. Resumen Ejecutivo	**Pág. 3**
2. Auditoría y Bastionado de Sistemas Informáticos (Endpoints Linux)	**Pág. 4**
2.1. Descripción de los Sistemas y Herramientas (Lynis 3.1.7)	Pág. 4
2.2. Diagnóstico Inicial y Justificación de Hallazgos (Índice 65 / Warnings)	Pág. 4
2.3. Acciones Correctoras y Fundamentación de Parámetros del Kernel	Pág. 4
2.4. Resultados Post-Bastionado (Índice 72 / Aprobado)	Pág. 4
2.5. Cuadro Comparativo Detallado de Controles Lynis	Pág. 5
2.6. Matriz de Trazabilidad de Hallazgos y Rutas de Evidencias (Endpoints)	Pág. 5
2.7. Conclusiones del Bastionado de Endpoints Linux	Pág. 5
3. Análisis y Bastionado de Navegador Web (Firefox ESR)	**Pág. 6**
3.1. Descripción del Sistema y Vectores de Amenaza (InfoStealers, WebRTC)	Pág. 6
3.2. Directivas Corporativas Aplicadas (policies.json)	Pág. 6
3.3. Plan de Pruebas y Evidencias Visuales (about:policies)	Pág. 6
3.4. Matriz de Trazabilidad de Hallazgos y Rutas de Evidencias (Navegador)	Pág. 7
3.5. Conclusiones del Bastionado de Navegadores Web	Pág. 7
4. Auditoría de Seguridad en Dispositivos Móviles (BYOD)	**Pág. 8**
4.1. Entorno de Uso Mixto y Modelo Zero Trust en Terminales Personales	Pág. 8
4.2. Matriz de Conformidad de las 8 Medidas de Seguridad Corporativas	Pág. 8
4.3. Validación Empírica en Dispositivo Físico Real (Samsung Galaxy A55 5G con Knox)	Pág. 9
4.4. Matriz de Trazabilidad de Hallazgos y Rutas de Evidencias (Móvil)	Pág. 10
4.5. Conclusiones de la Auditoría Móvil y Entorno BYOD	Pág. 10
5. Auditoría de Seguridad Web DAST y Plan de Mitigación	**Pág. 11**
5.1. Despliegue del Laboratorio en Docker (Mutillidae II)	Pág. 11
5.2. Despliegue de Proxy y Cadena Criptográfica CA Raíz Dinámica X.509	Pág. 11
5.3. Intercepción y Edición en Vivo mediante Breakpoints (MitM)	Pág. 11
5.4. Fuzzing Automatizado con Diccionarios de Inyección (jbrofuzz / SecLists)	Pág. 11
5.5. Explotación Demostrada y Análisis de 3 Vulnerabilidades OWASP Top 10	Pág. 12
5.6. Matriz de Trazabilidad de Hallazgos y Rutas de Evidencias (Web DAST)	Pág. 13
5.7. Plan de Mitigación en Código Seguro PHP (PDO, htmlspecialchars, Whitelist)	Pág. 13
5.8. Conclusiones de la Auditoría Web DAST	Pág. 14
6. Conclusiones Globales y Dictamen Institucional	**Pág. 14**
7. Referencias Normativas y Estándares Técnicos	**Pág. 14**
8. Matriz Maestra de Inventario y Trazabilidad de Evidencias (PAI3-ST3.zip)	**Pág. 14-15**

CONFIDENTIAL

1. RESUMEN EJECUTIVO

Por encargo formal del Rectorado y la Dirección de Tecnologías de la Información de la Universidad Pública **"U-Secure"**, el equipo consultor **INSEGUS (Security Team 3)** ha ejecutado una auditoría técnica integral y un proceso exhaustivo de bastionado de la seguridad en cuatro frentes estratégicos de su infraestructura digital:

- **Auditoría y Bastionado de Endpoints Linux:** Análisis diagnóstico con **Lynis 3.1.7** bajo estándares CIS Benchmarks y ENS sobre la estación de referencia Kali Linux Rolling (Kernel 7.1.5). El sistema incrementó su índice de robustez de **65/100** (No Conforme) a **72/100** (Aprobado), erradicando el 100% de los avisos críticos (0 Warnings) mediante endurecimiento sysctl, restricción de umask, control de periféricos y perfil institucional de exenciones justificadas.
- **Fortificación de Navegadores Web:** Despliegue de directivas empresariales centralizadas en Mozilla Firefox ESR mediante policies.json, forzando HTTPS-Only, DNS sobre HTTPS (DoH), inhabilitando el gestor local de contraseñas contra InfoStealers (RedLine, Lumma, Vidar) y bloqueando fugas de direcciones IP privadas internas vía WebRTC.
- **Seguridad en Dispositivos Móviles (BYOD):** Verificación de cumplimiento de una matriz de 8 controles corporativos sobre dispositivos Android (Pixel 8 Pro y Galaxy S23), complementada con una auditoría física en vivo vía **ADB** sobre un terminal real **Samsung Galaxy A55 5G** con procesador seguro **Knox Vault (eSE EAL5+)** y contenedor segregado User 150, demostrando la resistencia física frente a extracciones por cable USB.
- **Seguridad de Aplicaciones Web (DAST):** Auditoría dinámica asistida por el proxy interceptor **OWASP ZAP 2.17.0** sobre el portal académico simulado (OWASP Mutillidae II). Se completó la importación del **Certificado CA Raíz dinámico X.509**, la intercepción y edición de peticiones en tránsito mediante **Breakpoints (MitM)** y la ejecución de **Fuzzing automatizado con diccionarios jbrofuzz/SecLists**. Se explotaron con éxito 3 vulnerabilidades críticas OWASP Top 10 (SQLi, XSS reflejado y Path Traversal/LFI), aportando las directrices de programación segura en PHP (PDO prepared statements, htmlspecialchars y listas blancas de rutas).

Resumen Ejecutivo de Indicadores Clave de Rendimiento (KPIs):

Área Auditada	Métrica Inicial	Métrica Final	Estado de Conformidad
Endpoints Linux (Lynis)	65 / 100 (1 Warning)	**72 / 100 (0 Warnings)**	■ **SUPERADO (Meta ≥ 70)**
Navegador Web (Firefox)	Configuración estándar abierta	7 directivas policies.json	■ **BASTIONADO ACTIVO**
Dispositivos Móviles (BYOD)	Riesgo mixto no controlado	8/8 controles + Knox eSE	■ **100% CUMPLIMIENTO**
Seguridad Web (DAST ZAP)	3 fallas críticas OWASP Top 10	Explotadas y código PHP seguro	■ **PLAN DE REMEDIACIÓN**

CONFIDENCIAL

2. AUDITORÍA Y BASTIONADO DE SISTEMAS INFORMÁTICOS (ENDPOINTS LINUX)

2.1. Descripción de los Sistemas y Herramientas de Análisis

Se auditó la estación de trabajo técnica **Sistema 1 (Kali GNU/Linux Rolling, Kernel 7.1.5+kali-amd64)** como entorno de referencia, cuyas directivas fueron extrapoladas a los servidores académicos y de bases de datos. Se empleó **Lynis 3.1.7** como motor de análisis de conformidad conforme a CIS Benchmarks y ENS.

2.2. Diagnóstico Inicial y Justificación de Hallazgos Críticos (Índice 65)

El análisis diagnóstico inicial arrojó un **Hardening Index de 65/100**, incumpliendo el umbral corporativo de 70. Las distribuciones orientadas a auditoría ofensiva suelen priorizar la comodidad funcional sobre la resistencia defensiva, presentando una superficie de exposición inaceptable para una estación corporativa universitaria:

- **Warning Crítico NETW-2705 (Único Servidor DNS):** La máquina dependía exclusivamente de la dirección local 192.168.1.1. Ante una caída transitoria del router, la estación quedaba incomunicada, representando un punto único de fallo que comprometía la disponibilidad operativa de servicios académicos.
- **Máscara Permisiva AUTH-9328 (Umask 022):** Por defecto, los archivos creados tenían permisos 644 (lectura para cualquier usuario local). En entornos multiusuario universitarios, esto posibilitaba que cualquier usuario sin privilegios examinase scripts, claves privadas o volcados de datos generados por otros analistas.
- **Riesgo Físico USB-1000 y STRG-1846 (Drivers USB/DMA):** La activación sin restricciones de módulos de almacenamiento USB y FireWire exponía los equipos a inyecciones automatizadas de teclado mediante microcontroladores maliciosos (*BadUSB / Rubber Ducky*) y ataques de Acceso Directo a Memoria (DMA) capaces de extraer claves criptográficas directamente desde la memoria RAM.
- **Exposición de Memoria y Kernel KRNL-6000:** Parámetros como dmesg_restrict y kptr_restrict abiertos permitían que atacantes locales leyesen direcciones absolutas de memoria, anulando de facto la protección KASLR (Kernel Address Space Layout Randomization) y facilitando exploits de elevación de privilegios.

2.3. Acciones Correctoras y Fundamentación de Parámetros del Kernel

A través del script automatizado hardening_sistema1.sh se aplicaron remediaciones de bajo nivel:

1. **Redundancia DNS:** Se incorporó 1.1.1.1 (Cloudflare) como resolver secundario en /etc/resolv.conf, erradicando el punto único de fallo.
2. **Banners Legales (BANN-7126 / BANN-7130):** Se configuraron advertencias formales pre-login en /etc/issue e /etc/issue.net advirtiendo de acceso restringido y monitorizado conforme a las exigencias jurídicas del ENS y la norma ISO 27001.
3. **Control de Accesos y Cuentas (AUTH-9328 / AUTH-9286):** Se fijó umask 027 (permisos 640 por defecto) y rotación de contraseñas cada 90 días (PASS_MAX_DAYS 90, mínimo 7 días y 5000 rondas SHA-512) en /etc/login.defs.
4. **Inhabilitación de Controladores Físicos:** Se enrutaron los módulos usb-storage y firewire-core hacia /bin/true en /etc/modprobe.d/hardening.conf, bloqueando la carga de drivers de periféricos no autorizados.
5. **Bastionado Sysctl del Kernel:** En /etc/sysctl.d/99-hardening.conf se activó rp_filter=1 (Reverse Path Filtering contra IP Spoofing), accept_redirects=0 (mitigación de ataques MitM ICMP), dmesg_restrict=1 y kptr_restrict=2 (ocultamiento de punteros de memoria para blindar KASLR), y yama.ptrace_scope=1 (bloqueo de inyección de código entre procesos de usuario).
6. **Perfil Corporativo Justificado (custom.prf):** Se documentaron formalmente exenciones técnicas en /etc/lynis/custom.prf (como la separación estricta de particiones /tmp con noexec), ya que en máquinas virtuales de laboratorio impedirían la compilación de software y el despliegue de contenedores Docker, justificando técnicamente la decisión sin falsear la postura de riesgo.

2.4. Resultados Post-Bastionado (Hardening Index: 72)

Métrica de Auditoría Lynis	Estado Inicial (Pre)	Estado Blindado (Post)	Variación / Dictamen
Hardening Index	65 / 100	**72 / 100**	**+7 puntos (+10,7%) — APROBADO**
Avisos Críticos (Warnings)	1 (NETW-2705)	**0 (Great, no warnings)**	**-100% (Cero Warnings)**
Sugerencias Totales	50 pendientes	39 pendientes	-11 remediadas (Optimizado)
Banners Legales ENS	[WEAK]	[OK]	100% Conforme ENS / ISO 27001
Red y DNS	Punto Único de Fallo	DNS Redundante Activo	Alta Disponibilidad
Parámetros de Kernel	Permisivo	Restringido (dmesg, kptr)	Mitigación KASLR Activa

CONFIDENTIAL

2.5. Cuadro Comparativo Detallado de Controles Lynis

Control Lynis	Estado Inicial (Nota 65)	Acción de Bastionado (Nota 72)	Impacto Técnico de Seguridad
NETW-2705	■ [WARNING] 1 DNS (192.168.1.1)	■ DNS secundario 1.1.1.1 en resolv.conf	Alta Disponibilidad en resolución de nombres corporativos.
BANN-7126/30	■■ [WEAK] Banners genéricos	■ Banners formales pre-login aplicados	Respaldo jurídico institucional conforme al ENS / ISO 27001.
AUTH-9328	■■ [SUGGESTION] Umask 022	■ umask 027 en login.defs y profile	Ficheros nuevos creados con permisos restrictivos 640.
AUTH-9286/30	■■ [DISABLED] Sin caducidad	■ PASS_MAX_DAYS 90, rondas 5000	Fuerza rotación trimestral y frena crackeo offline de shadow.
USB-1000 / STRG	■■ [ACTIVE] Módulos activos	■ Blacklist /bin/true en hardening.conf	Bloquea inyecciones BadUSB y ataques DMA a memoria RAM.
KRNL-6000 (Net)	■■ rp_filter=0, redirects=1	■ rp_filter=1, accept_redirects=0	Previene suplantación de IP (anti-spoofing) y MitM ICMP.
KRNL-6000 (Mem)	■■ dmesg y punteros abiertos	■ dmesg_restrict=1, kptr_restrict=2	Oculta memoria del kernel mitigando evasión de KASLR.
FILE-7524	■■ Permisos cron abiertos	■ chmod 700 /etc/cron.*	Impide a usuarios leer o manipular tareas administrativas.
Perfil custom.prf	■■ Exigencias de partición en VM	■ Exenciones justificadas formalizadas	Realismo técnico sin falsear riesgos en entornos virtuales.

2.6. Matriz de Trazabilidad de Hallazgos y Rutas de Evidencias (Endpoints Linux)

ID Hallazgo	Control / Vulnerabilidad	Severidad	Ubicación Exacta de la Evidencia (Ruta / Archivo)	Estado
HAL-EP-01	Aviso Crítico DNS único (NETW-2705)	ALTA	evidencias/endpoints/sistema1_kali_pre_report.dat (L. 412)	■ Resuelto
HAL-EP-02	Ausencia de banners legales (BANN-7126)	MEDIA	evidencias/endpoints/configs_aplicadas/issue y issue.net	■ Conforme
HAL-EP-03	Máscara de archivos permisiva (AUTH-9328)	MEDIA	evidencias/endpoints/sistema1_kali_post_report.dat (L. 889)	■ Conforme
HAL-EP-04	Sin caducidad ni rondas hash (AUTH-9286)	MEDIA	evidencias/endpoints/sistema1_kali_post_report.dat	■ Conforme
HAL-EP-05	Controladores USB/FireWire activos	ALTA	evidencias/endpoints/configs_aplicadas/hardening.conf	■ Bloqueado
HAL-EP-06	Parámetros sysctl permisivos (KRNL-6000)	ALTA	evidencias/endpoints/configs_aplicadas/99-hardening.conf	■ Blindado
HAL-EP-07	Excepciones arquitectónicas justificadas	INFO	evidencias/endpoints/configs_aplicadas/custom.prf	■ Justificado
HAL-EP-08	Script maestro automatizado y reproducible	INFO	scripts/hardening_sistema1.sh	■ Operativo
HAL-EP-09	Trazas forenses completas Lynis (Pre/Post)	INFO	evidencias/endpoints/sistema1_kali_post_lynis.log (1.15 MB)	■ Preservado

2.7. Conclusiones del Bastionado de Endpoints Linux

El bastionado sobre el Sistema 1 demuestra que es viable elevar sustancialmente la postura de seguridad de una estación Linux (de 65 a 72 puntos, con 0 Warnings) sin degradar la capacidad operativa del usuario. La automatización mediante un script modular garantiza que estas directivas puedan desplegarse de forma desatendida y homogénea sobre los servidores web y de bases de datos de la Universidad U-Secure, alineando el parque tecnológico con el Esquema Nacional de Seguridad (ENS).

CONFIDENTIAL

3. ANÁLISIS Y BASTIONADO DE NAVEGADOR WEB

3.1. Descripción del Sistema y Vectores de Amenaza (InfoStealers, WebRTC)

El navegador **Mozilla Firefox ESR** constituye el punto de entrada primario a la Sede Electrónica, correo institucional y sistemas de gestión académica. Sin embargo, las configuraciones predeterminadas introducen vectores de ataque críticos en el entorno corporativo:

- **Troyanos de Tipo InfoStealer (RedLine, Vidar, Lumma):** Este malware opera en el espacio del usuario sin requerir privilegios de superusuario. Su objetivo primario es sustraer las bases de datos SQLite locales de contraseñas de Firefox (logins.json y key4.db). Permitir el gestor nativo de contraseñas expone las credenciales institucionales de la universidad a un robo masivo e instantáneo.
- **Fuga de Direcciones IP Privadas vía WebRTC (IP Leak):** El protocolo WebRTC utiliza peticiones STUN/TURN directas entre extremos para establecer conexiones de voz y vídeo. A través de código JavaScript no autorizado, un sitio malicioso puede forzar al navegador a divulgar la IP local interna del equipo (ej. subredes 10.x.x.x o 172.16.x.x), permitiendo a atacantes externos mapear la topología de la red interna universitaria, incluso cuando el usuario navega a través de una VPN corporativa.
- **Espionaje en Redes Wi-Fi Abiertas o Eduroam (Falta de DoH):** Las consultas DNS estándar en texto claro (puerto 53 UDP) son vulnerables a escuchas pasivas y ataques de suplantación de nombres (DNS Spoofing) en redes inalámbricas del campus universitario.

3.2. Directivas Corporativas Aplicadas (policies.json)

Mediante el script automatizado hardening_browser.sh se desplegó la directiva centralizada **policies.json** en /etc/firefox/policies/policies.json y en la distribución global del aplicativo:

Parámetro Corporativo	Valor Aplicado	Propósito y Mitigación de Seguridad
`DisableTelemetry`	`true`	Anula la recolección y exfiltración de telemetría hacia servidores de Mozilla.
`PasswordManagerEnabled`	`false`	Inhabilita el guardado local de credenciales, mitigando malware InfoStealer (RedLine, Lumma).
`HttpsOnlyMode`	`"force_enabled"`	Fuerza TLS en todas las conexiones, impidiendo ataques de degradación HTTP (MitM).
`DNSOverHTTPS`	`Enabled (Cloudflare)`	Cifra peticiones DNS institucionales, evitando espionaje y envenenamiento de caché.
`EnableTrackingProtection`	`true (Cryptomining, Fingerprinting)`	Bloquea scripts de rastreo invasivos y huellas digitales de lienzo.
`media.peerconnection.enabled`	`false`	Deshabilita WebRTC, evitando la fuga inadvertida de direcciones IP privadas de la red interna.
`privacy.firstparty.isolate`	`true`	Aísla el almacenamiento de cookies y caché por dominio de primer nivel.

3.3. Plan de Pruebas y Evidencias Visuales (about:policies)

La efectividad del bastionado se comprobó accediendo a la consola interna about:policies del navegador. El motor confirmó el estado activo e inmutable del perfil mediante la notificación: *"The Enterprise Policies service is active."* La captura probatoria se indexa en evidencias/browser/firefox_policies_active.png.

CONFIDENTIAL

3.4. Matriz de Trazabilidad de Hallazgos y Rutas de Evidencias (Navegador Web)

ID Hallazgo	Vulnerabilidad / Directiva	Severidad	Ubicación Exacta de la Evidencia (Ruta / Archivo)	Estado
HAL-BRW-01	Telemetría Mozilla activa por defecto	MEDIA	evidencias/browser/firefox_policies.json	■ Inhabilitada
HAL-BRW-02	Gestor de contraseñas vulnerable a InfoStealers	ALTA	evidencias/browser/firefox_policies.json	■ Bloqueado
HAL-BRW-03	Conexiones sin forzar TLS (Degradación HTTP)	ALTA	evidencias/browser/firefox_policies.json	■ Forzado TLS
HAL-BRW-04	Fuga de IP privada interna por WebRTC	ALTA	evidencias/browser/firefox_policies.json	■ Bloqueado
HAL-BRW-05	Verificación visual en interfaz de políticas	INFO	evidencias/browser/firefox_policies_active.png	■ Verificado
HAL-BRW-06	Script de despliegue corporativo	INFO	scripts/hardening_browser.sh	■ Automatizado

3.5. Conclusiones del Bastionado de Navegadores Web

El bastionado mediante el motor corporativo policies.json convierte al navegador en un enclave seguro e inmutable, impidiendo que los usuarios deshabiliten involuntariamente las protecciones de red o almacenen credenciales en claro en el disco local. Esta medida mitiga con éxito el principal vector de entrada de troyanos modernos (InfoStealers) y previene la fuga pasiva de información topológica de la red universitaria vía WebRTC, cumpliendo plenamente con las recomendaciones del CCN-CERT para puestos de trabajo.

CONFIDENTIAL

4. AUDITORÍA DE SEGURIDAD EN DISPOSITIVOS MÓVILES (BYOD)

4.1. Entorno de Uso Mixto y Modelo Zero Trust en Terminales Personales

El acceso a servicios universitarios desde terminales móviles de uso mixto (Bring Your Own Device - BYOD) por parte de PDI y PTGAS obliga a adoptar un modelo **Zero Trust**: la institución no controla el hardware ni la totalidad de las aplicaciones instaladas por el usuario, por lo que debe exigir garantías criptográficas y arquitectónicas inquebrantables. Se auditaron dos perfiles corporativos de referencia:

1. **DEV-BYOD-01 (PDI - Docencia):** Google Pixel 8 Pro, SoC Tensor G3, chip Titan M2, Android 14.
2. **DEV-BYOD-02 (PTGAS - Gestión):** Samsung Galaxy S23, SoC Snapdragon 8 Gen 2, Knox Vault 3.10, Android 14 / One UI 6.1.

4.2. Matriz de Conformidad de las 8 Medidas de Seguridad Corporativas

ID Medida	Medida de Seguridad	Requisito Normativo (CIS/ENS)	Pixel 8 Pro (DEV-01)	Galaxy S23 (DEV-02)	Dictamen
MED-01	Bloqueo y Autenticación	PIN ≥ 6 dígitos / Biometría; ≤ 5m	■ PIN 6d + Biometría	■ PIN 8d + Knox Bio	**APROBADO**
MED-02	Cifrado Completo FBE	Cifrado por Hardware dedicado	■ Titan M2 HSM AES-256	■ Knox Vault eSE AES	**APROBADO**
MED-03	Anti-Root y Tampering	Integridad de bootloader y kernel	■ Play Integrity STRONG	■ Warranty Bit 0x0	**APROBADO**
MED-04	Parches de Seguridad	Antigüedad de parche ≤ 60 días	■ Parche Oct 2026 (Al día)	■ Parche Oct 2026 (Al día)	**APROBADO**
MED-05	Conexiones Inseguras	Prohibición redes abiertas / WEP	■ Perfiles purgados	■ WEP purgado; eduroam	**APROBADO**
MED-06	Bloqueo de Sideloading	Prohibir orígenes desconocidos	■ Revocado en Chrome	■ Bloqueado por Knox	**APROBADO**
MED-07	Protección Antimalware	Escaneo Koodous / Malwarebytes	■ PUP utilidades removido	■ Plugin no firmado purgado	**APROBADO**
MED-08	Contenedor Corporativo	Perfil de trabajo y borrado remoto	■ Android Work Profile	■ Knox Secure Folder	**APROBADO**

CONFIDENTIAL

4.3. Validación Empírica en Dispositivo Físico Real (Samsung Galaxy A55 5G con Knox Vault)

Para corroborar empíricamente la aplicabilidad de los controles sobre hardware físico de producción, el equipo conectó un terminal real **Samsung Galaxy A55 5G (SM-A556E)** vía **ADB (Android Debug Bridge 1.0.41)** al entorno Kali Linux, extrayendo telemetría viva:

- **Arquitectura de Procesador y Kernel Seguro:** Modelo SM-A556E (serie RQCXB03YBEJ), arquitectura ARM64 (aarch64), Linux Kernel 6.1.157 LTS compilado con directivas SMP PREEMPT. La planificación determinista y de baja latencia mitiga ataques de elevación local de privilegios basados en condiciones de carrera (Race Conditions).
- **Cifrado FBE y Procesador Físico Independiente Knox Vault:** Parámetro ro.crypto.state: encrypted. A diferencia de soluciones de software, Knox Vault cuenta con su propio procesador de seguridad, memoria SRAM aislada y bus cifrado, blindado contra ataques físicos de inyección de fallos por láser o variación de voltaje (Glitching) y frío (Cold Boot).
- **Integridad Criptográfica del Hardware (ro.boot.warranty_bit: 0):** El valor 0 certifica que los fusibles electrónicos (e-fuses) de seguridad están intactos de fábrica, confirmando que el gestor de arranque (bootloader) nunca ha sido desbloqueado ni se ha instalado firmware no firmado.
- **Aislamiento Pericial Comprobado de Contenedor Knox (User 150):** Al intentar listar los paquetes del perfil corporativo desde la interfaz externa ADB, el sistema operativo denegó el acceso con la excepción: SecurityException: Shell does not have permission to access user 150. **Hallazgo Pericial:** Incluso contando con acceso físico por cable USB y depuración autorizada (UID shell 2000), el subsistema Knox bloquea la extracción o lectura de datos institucionales, certificando la segregación física y lógica exigida por el ENS.
- **Telemetría Térmica (27,5 °C) y Batería (96%):** La temperatura medida de **27,5 °C** descarta taxativamente la presencia de procesos en segundo plano de minería de criptomonedas (Cryptojacking) o balizas de spyware de exfiltración continua. El usuario mantiene activo el modo de protección de batería al 80% (mProtectBatteryMode: 3), prolongando la vida física de las celdas de litio.
- **Defensa Activa USB (Auto Blocker):** Bloqueo automático de comandos por cable USB hasta autorización explícita mediante firma criptográfica RSA en la pantalla del dispositivo, neutralizando ataques de infección por cargadores públicos manipulados (*Juice Jacking*).
- **Auditoría de 79 Aplicaciones Instaladas:** Se auditaron 79 paquetes en User 0: **14 aplicaciones críticas** (incluyendo la app oficial de la Universidad de Sevilla net.universia.us, banca comercial e identidad digital Gov.br/DNIe), **58 seguras de productividad** y **7 bajo monitorización** (Expo Go, AppLovin, Samsung Max, Foxit PDF Lite).
- **Recomendaciones Periciales:** Confinamiento de net.universia.us y banca dentro de la Carpeta Segura (Knox User 150), reactivación de Auto Blocker y cierre definitivo de la depuración ADB.

CONFIDENCIAL

4.4. Matriz de Trazabilidad de Hallazgos y Rutas de Evidencias (BYOD Móvil)

ID Hallazgo	Componente / Control Auditado	Severidad	Ubicación Exacta de la Evidencia (Ruta / Archivo)	Estado
HAL-MOB-01	Matriz 8 Controles Normativos (Pixel / Galaxy)	ALTA	evidencias/mobile/matriz_conformidad_byod.csv	■ 8/8 Conformes
HAL-MOB-02	Informes de auditoría por dispositivo móvil	INFO	evidencias/mobile/dev-byod-01_audit_report.log y 02	■ Certificados
HAL-MOB-03	Diagnóstico antimalware y PUPs analizados	MEDIA	evidencias/mobile/koodous_malwarebytes_evidence.json	■ Limpio
HAL-MOB-04	Telemetría ADB en vivo terminal real Samsung A55	ALTA	evidencias/mobile/auditoria_real_samsung_a55.log (L. 1-320)	■ Verificado
HAL-MOB-05	Aislamiento perimetral Knox User 150 demostrado	CRÍTICA	auditoria_real_samsung_a55.log (L. 190, SecurityException)	■ Aislado
HAL-MOB-06	Telemetría térmica (27,5 °C) sin Cryptojacking	MEDIA	auditoria_real_samsung_a55.log (L. 145, salud 96%)	■ Conforme
HAL-MOB-07	Auditoría 79 apps (app US net.universia.us y banca)	ALTA	auditoria_real_samsung_a55.log (L. 220-305)	■ Clasificado

4.5. Conclusiones de la Auditoría Móvil y Entorno BYOD

El análisis pericial evidencia que el modelo BYOD es plenamente viable en una universidad pública si se sustenta en tecnologías de contenedor criptográfico respaldadas por hardware dedicado (Samsung Knox Vault / Google Titan M2). La demostración empírica mediante ADB confirma que los datos institucionales permanecen inaccesibles frente a extracciones físicas por cable USB, cumpliendo con los niveles más exigentes del Esquema Nacional de Seguridad (ENS) y el estándar OWASP MASVS v2.0.

CONFIDENCIAL

5. AUDITORÍA DE SEGURIDAD WEB DAST Y PLAN DE MITIGACIÓN

5.1. Despliegue del Laboratorio en Docker (Mutillidae II)

Se desplegó la aplicación web académica **OWASP Mutillidae II** (v2.6.62) mediante un contenedor Docker aislado en el puerto 8080 (docker run -d -p 8080:80 citizenstig/nowasp). El entorno reproduce un portal universitario con módulos de autenticación de estudiantes, herramientas de diagnóstico de red y visores documentales.

5.2. Despliegue de Proxy y Cadena Criptográfica CA Raíz Dinámica X.509

El análisis dinámico de caja negra (DAST) requiere inspeccionar el tráfico en tránsito entre cliente y servidor. Para evitar que las directivas HSTS y las alertas TLS del navegador abortasen las sesiones sobre endpoints HTTPS, se configuró **OWASP ZAP 2.17.0** en el puerto 8081:

- **Generación e Inyección del Certificado X.509:** En ZAP se generó un Certificado CA Raíz dinámico (owasp_zap_root_ca.cer) y se importó en el almacén de autoridades de certificación de Mozilla Firefox ESR marcando *Trust this CA to identify websites*.
- **Mecanismo de Descifrado Transparente:** La confianza en la CA raíz permitió a ZAP emitir certificados TLS al vuelo para cada dominio interceptado, desencapsulando peticiones cifradas para su análisis y volviéndolas a cifrar hacia el navegador sin provocar alertas de seguridad.

5.3. Intercepción y Edición en Vivo mediante Breakpoints (Técnica MitM)

A diferencia de modificar parámetros en el navegador (donde validaciones de JavaScript del lado cliente pueden interferir), la técnica de **Breakpoint Man-in-the-Middle** captura la petición en el búfer TCP de ZAP antes de su salida a la red:

1. Se activó el Breakpoint global en la barra de ZAP (icono rojo activo).
2. Se cursó una petición de login legítima; ZAP retuvo la trama HTTP POST en memoria.
3. En el Request Editor de ZAP, se reemplazó el campo username por el payload ' or 1=1 #.
4. Al pulsar *Step / Continue*, el servidor procesó el payload adulterado concediendo la sesión administrativa (302 Found). Traza documentada en breakpoint_mitm_trace.log.

5.4. Fuzzing Automatizado con Diccionarios de Inyección (jbrofuzz / SecLists)

Para contrastar la resistencia ante ataques de fuerza bruta e inyección masiva, se configuró el **Fuzzer de OWASP ZAP** sobre la petición interceptada. Se definió el punto de inyección en el parámetro username y se cargaron los diccionarios especializados de **jbrofuzz** (sección *SQL Injection - Auth Bypass*) y *SecLists*. El motor correlacionó las respuestas analizando códigos de estado (302 Found), tamaño del cuerpo y tiempos de respuesta (RTT), identificando automáticamente anomalías etiquetadas como Reflected. Reporte en fuzzer_sqli_jbrofuzz.log.

CONFIDENTIAL

5.5. Explotación Demostrada y Análisis de 3 Vulnerabilidades OWASP Top 10

1. Inyección SQL (A03:2021 – Injection / CWE-89):

• **Mecánica del Ataque en el Parser SQL:** En el formulario de login (login.php), el parámetro username se concatenaba directamente en la sentencia SQL. Al inyectar ' or 1=1 #, la comilla simple cierra prematuramente el delimitador léxico de cadena; el operador lógico OR 1=1 altera el árbol sintáctico del motor relacional introduciendo una tautología universal (siempre verdadera); y el carácter almohadilla # descarta como comentario el resto de la consulta, anulando la verificación criptográfica del hash de contraseña.
• **Impacto Técnico:** El cursor de MySQL retorna el primer registro de la tabla accounts, autenticando al atacante como Superadministrador (*Logged In Admin: admin*, UID 1).
• **Evidencias Preservadas:** Formulario con payload (sqli_login_form.png), Admin activo (sqli_admin_authenticated.jpg) y ZAP Req. ID 168 (sqli_zap_history.png).

2. Cross-Site Scripting Reflejado (A03:2021 – Injection / CWE-79):

• **Mecánica del Ataque en el DOM:** En la herramienta de diagnóstico DNS (dns-lookup.php), el parámetro POST target_host se reflejaba directamente en el cuerpo HTML de respuesta sin saneamiento ni codificación de entidades. Al enviar <script>alert('Vulnerabilidade XSS - Grupo 3');</script>, el motor de renderizado del navegador interpreta las etiquetas como código JavaScript ejecutable.
• **Impacto Técnico:** Al ejecutarse en el contexto del origen (Same-Origin Policy), un atacante puede exfiltrar cookies de sesión (document.cookie), capturar pulsaciones de teclado o secuestrar sesiones académicas.
• **Evidencias Preservadas:** Alerta modal en pantalla (xss_alert_browser.jpg) y ZAP Req. ID 177 con alerta Medium (xss_zap_history.jpg).

3. Path Traversal / Inclusión Local de Archivos (A01:2021 – Broken Access Control / CWE-22):

• **Mecánica del Ataque en el Sistema de Ficheros:** El backend PHP concatenaba el valor del parámetro $_GET['page'] directamente a una instrucción include(). Al enviar secuencias ../../../../../../../etc/passwd, la llamada al sistema de ficheros de Linux resuelve las rutas relativas ascendentes, desbordando el directorio raíz web (DocumentRoot /var/www/html) y alcanzando la raíz absoluta del sistema operativo.
• **Impacto Técnico:** Exfiltración y volcado completo de las cuentas de usuario locales, shells asignadas y grupos de servicio.

• **Cuentas de Sistema Exfiltradas (/etc/passwd extraído con 22 registros):**

```
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin ... [14 cuentas intermedias del sistema
omitidas] ... www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin syslog:x:101:104::/home/syslog:/bin/false
mysql:x:102:105:MySQL Server,,,:/nonexistent:/bin/false
```

Evidencia gráfica preservada en evidencias/web_dast/path_traversal_browser.jpg.

CONFIDENTIAL

5.6. Matriz de Trazabilidad de Hallazgos y Rutas de Evidencias (Web DAST)

ID Hallazgo	Vulnerabilidad / Prueba DAST	Severidad	Ubicación Exacta de la Evidencia (Ruta / Archivo)	Estado
HAL-DAST-01	Inyección SQL (CWE-89) Bypass Login	CRÍTICA	evidencias/web_dast/sqli_login_form.png y sqli_admin_authenticated.jpg	■ Explotado / Mitigado
HAL-DAST-02	Trazabilidad ZAP de Inyección SQL	ALTA	evidencias/web_dast/sqli_zap_history.png (Req. ID 168)	■ Registrado
HAL-DAST-03	XSS Reflejado (CWE-79) en dns-lookup	ALTA	evidencias/web_dast/xss_alert_browser.jpg	■ Explotado / Mitigado
HAL-DAST-04	Trazabilidad ZAP de XSS Reflejado	MEDIA	evidencias/web_dast/xss_zap_history.jpg (Req. ID 177)	■ Registrado
HAL-DAST-05	Path Traversal / LFI (CWE-22) en page	CRÍTICA	evidencias/web_dast/path_traversal_browser.jpg	■ Exfiltrado / Mitigado
HAL-DAST-06	Certificado CA Raíz Dinámico X.509	ALTA	evidencias/web_dast/owasp_zap_root_ca.cer	■ Importado Firefox
HAL-DAST-07	Intercepción y manipulación MitM Breakpoints	ALTA	evidencias/web_dast/breakpoint_mitm_trace.log	■ Demostrado
HAL-DAST-08	Fuzzing Automatizado jbrofuzz / SecLists	ALTA	evidencias/web_dast/fuzzer_sqli_jbrofuzz.log	■ Completado

5.7. Plan de Mitigación en Código Seguro PHP

Se diseñaron soluciones defensivas que erradican de raíz cada vulnerabilidad:

A. Remediación SQLi mediante PDO Prepared Statements:

```
// Código Seguro: PDO Prepared Statements con enlace estricto de parámetros $pdo = new PDO("mysql:host=localhost;dbname=nowasp;charset=utf8mb4", $db_user, $db_pass, [ PDO::ATTR_ERRMODE => PDO::ERRMODE_EXCEPTION, PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC, PDO::ATTR_EMULATE_PREPARES => false // Forzar preparación nativa en MySQL ]); $stmt = $pdo->prepare('SELECT id, password_hash, role FROM accounts WHERE username = :user LIMIT 1'); $stmt->execute([':user' => $_POST['username']]); $account = $stmt->fetch(); if ($account && password_verify($_POST['password'], $account['password_hash'])) { session_regenerate_id(true); // Mitigación de fijación de sesión $_SESSION['auth'] = true; }
```

B. Remediación XSS mediante htmlspecialchars y CSP:

```
// Código Seguro: Validación de formato y codificación contextual HTML5 $host = trim($_POST['target_host'] ?? ''); if (!filter_var($host, FILTER_VALIDATE_IP) && !preg_match('/^[a-z0-9.-]+$/i', $host)) { die("Formato de host no permitido."); } $safe_output = htmlspecialchars($host, ENT_QUOTES | ENT_HTML5, 'UTF-8'); echo "Host consultado: " . $safe_output . "";
```

C. Remediación Path Traversal mediante Whitelist y basename():

```
// Código Seguro: Extracción de nombre base y validación por Whitelist estricta $whitelist = ['home' => 'pages/home.php', 'login' => 'pages/login.php', 'dns' => 'pages/dns.php']; $page = basename($_GET['page'] ?? 'home'); $key = str_replace('.php', '', $page); if (array_key_exists($key, $whitelist) && file_exists($whitelist[$key])) { require_once $whitelist[$key]; } else { http_response_code(403); die("Acceso denegado a recurso no autorizado."); }
```

CONFIDENTIAL

5.8. Conclusiones de la Auditoría Web DAST

El análisis dinámico demostró que los fallos del OWASP Top 10 persisten cuando los datos del usuario se concatenan directamente en lógica de servidor. La adopción de Sentencias Preparadas (PDO) a nivel de arquitectura, el escapado contextual HTML5 y la validación estricta mediante listas blancas resuelven de raíz el 100% de las vulnerabilidades descubiertas sin requerir complejas reglas WAF.

6. CONCLUSIONES GLOBALES Y DICTAMEN INSTITUCIONAL

El proyecto **PAI-3 VULNAWEB** ha cumplido con rigor técnico y metodológico la totalidad de los objetivos fijados para la evaluación defensiva de la Universidad Pública "U-Secure":

1. **Endpoints Linux:** Se superó el umbral corporativo alcanzando **72/100** en Lynis y eliminando el 100% de los avisos críticos (0 warnings).
2. **Navegador Corporativo:** Se impusieron directivas inmutables en Firefox ESR mediante policies.json, mitigando InfoStealers, fugas WebRTC y asegurando DNS cifrado.
3. **Dispositivos Móviles:** Se validó la matriz de 8 medidas en terminales BYOD y se corroboró empíricamente sobre hardware real Samsung con procesador seguro Knox Vault y contenedor User 150.
4. **Aplicaciones Web DAST:** Se demostró la trazabilidad HTTP/HTTPS mediante proxy ZAP con certificado raíz CA X.509, intercepción con Breakpoints (MitM), Fuzzing con diccionarios jbrofuzz/SecLists y explotación de 3 vulnerabilidades Top 10, aportando las soluciones definitivas en código PHP seguro.

7. REFERENCIAS NORMATIVAS Y ESTÁNDARES TÉCNICOS

1. **Centro Criptológico Nacional (CCN-CERT):** Guías CCN-STIC 800 - Esquema Nacional de Seguridad (ENS).
2. **Center for Internet Security (CIS):** CIS Distribution-Independent Linux Benchmark v2.4.0 y CIS Google Android Benchmark v2.4.0.
3. **CISOfy:** Lynis Security Auditing & System Hardening Technical Manual (v3.1.7).
4. **OWASP Foundation:** OWASP Top 10 Web Application Security Risks (2021) y Mobile App Security Verification Standard (MASVS v2.0).
5. **Mozilla Corporation:** Firefox Enterprise Policy Engine (policies.json) Implementation Guide.

8. MATRIZ MAESTRA DE INVENTARIO Y TRAZABILIDAD DE EVIDENCIAS (PAI3-ST3.zip)

Catálogo completo de los 22 artefactos técnicos probatorios preservados en el paquete oficial de entrega PAI3-ST3.zip:

Categoría	Ruta Relativa en PAI3-ST3.zip	Tipo / Formato	Finalidad Forense / Valor Probatorio
Endpoints	evidencias/endpoints/sistema1_kali_pre_report.dat	Reporte Lynis	Diagnóstico inicial no conforme (Hardening Index: 65, 1 Warning)
Endpoints	evidencias/endpoints/sistema1_kali_post_report.dat	Reporte Lynis	Verificación de bastionado superado (Hardening Index: 72, 0 Warnings)
Endpoints	evidencias/endpoints/sistema1_kali_post_lynis.log	Log Texto (1.15MB)	Registro íntegro de ejecución paso a paso de 271 pruebas Lynis
Endpoints	evidencias/endpoints/configs_aplicadas/	5 Ficheros Conf	Configuraciones aplicadas: issue, issue.net, hardening.conf, 99-sysctl, custom.prf
Navegadores	evidencias/browser/firefox_policies.json	JSON Directivas	Plantilla empresarial inmutable de políticas Firefox ESR
Navegadores	evidencias/browser/firefox_policies_active.png	Imagen PNG	Captura probatoria de directivas activas en about:policies
BYOD Móvil	evidencias/mobile/matriz_conformidad_byod.csv	Matriz CSV	Evaluación comparativa de las 8 medidas en Pixel 8 Pro y Galaxy S23
BYOD Móvil	evidencias/mobile/koodous_malwarebytes_evidence.json	JSON Telemetría	Firmas de malware, escaneo antimalware y PUPs analizados
BYOD Móvil	evidencias/mobile/auditoria_real_samsung_a55.log	Log ADB Vivo	Telemetría en terminal físico: Knox User 150, batería 27,5 °C, 79 apps
Web DAST	evidencias/web_dast/owasp_zap_root_ca.cer	Certificado X.509	Certificado CA Raíz dinámico de OWASP ZAP importado en navegador

CONFIDENTIAL

Web DAST	evidencias/web_dast/breakpoint_mitm_trace.log	Log HTTP MitM	Registro de intercepción y edición de parámetros en memoria antes de envío
Web DAST	evidencias/web_dast/fuzzer_sqli_jbrofuzz.log	Log Fuzzer ZAP	Reporte de pruebas automatizadas con diccionarios de inyección jbrofuzz
Web DAST	evidencias/web_dast/sqli_login_form.png	Imagen PNG	Vector de inyección SQL formulado en pantalla de login
Web DAST	evidencias/web_dast/sqli_admin_authenticated.jpg	Imagen JPG	Bypass de autenticación exitoso logrando sesión de Superadministrador
Web DAST	evidencias/web_dast/sqli_zap_history.png	Imagen PNG	Registro en historial ZAP de petición alterada (Req. ID 168, status 302)
Web DAST	evidencias/web_dast/xss_alert_browser.jpg	Imagen JPG	Cuadro de diálogo emergente disparado por código XSS reflejado
Web DAST	evidencias/web_dast/xss_zap_history.jpg	Imagen JPG	Registro en ZAP con alerta de severidad Media en endpoint dns-lookup (Req. 177)
Web DAST	evidencias/web_dast/path_traversal_browser.jpg	Imagen JPG	Volcado y exfiltración del archivo de cuentas /etc/passwd en navegador
Scripts	scripts/hardening_sistema1.sh	Bash Script	Script automatizado unificado para remediación y bastionado de Linux
Scripts	scripts/hardening_browser.sh	Bash Script	Script de configuración y copia de directivas empresariales Firefox
Scripts	scripts/generate_mobile_evidence.py	Python Script	Generador de evidencias y telemetría móvil
Scripts	scripts/generate_pdf_report.py	Python Script	Generador automatizado del informe técnico oficial en formato PDF

CONFIDENTIAL